

FACULDADE ACADITI

IAC – Inteligência de Ameaças Cibernéticas

KASEYA

Relatório de Threat Intelligence

CTI-2021-KSA07

Alunos:

André Luiz Taques
Camila de Paula
Cristiano Carvalho
Daniel Lima Sousa
Emerson Gonçalves
Eudes Silva
Flavio Carnieto
Odail Junior
Pablo Silva
Rodrigo Myotin

Investigação de incidente contra fornecedor Kaseya

- **Identificador do Incidente:** CTI-2021-KSA07
- **Data de Emissão:** 07 de Junho de 2026
- **Atores de Ameaça:** REvil / Sodinokibi
- **Alvo Primário:** Kaseya VSA (Servidores On-Premises)
- **Alvo Secundário:** Provedores de Serviços Gerenciados (MSPs) e Clientes Finais
- **Vetor de Ataque:** Supply Chain Attack / Exploração de Vulnerabilidade Zero-Day

07/06/2026

Crítico

Sumário Executivo

Em julho de 2021, o grupo de ransomware REvil (Sodinokibi) realizou uma campanha de grande impacto contra a plataforma Kaseya VSA, utilizada por MSPs para gerenciamento remoto de ambientes corporativos. O ataque explorou vulnerabilidades críticas em servidores VSA expostos à internet, permitindo a distribuição de uma atualização maliciosa para diversas organizações ao redor do mundo.

A campanha apresentou características de Supply Chain Attack, pois o comprometimento de servidores Kaseya possibilitou a propagação do ransomware para clientes administrados pelos MSPs afetados. Estima-se que entre 800 e 1.500 empresas tenham sido impactadas, sofrendo criptografia de arquivos e indisponibilidade operacional.

A investigação identificou a exploração da vulnerabilidade CVE-2021-30116, além do uso de técnicas como execução via PowerShell, DLL Side-Loading, desativação do Windows Defender e utilização do certutil.exe para execução do payload malicioso.

Os TTPs observados apresentam forte alinhamento com o framework MITRE ATT&CK, principalmente nas fases de Initial Access, Execution, Defense Evasion e Impact, consolidando o incidente como uma das campanhas de ransomware mais relevantes de 2021.

Pontos principais

- O ataque ocorreu em julho de 2021.
- O grupo responsável foi o REvil/Sodinokibi.
- O alvo principal foi a plataforma Kaseya VSA.
- A vulnerabilidade explorada foi a CVE-2021-30116.
- O ataque afetou MSPs e clientes downstream.
- Aproximadamente 1.500 organizações foram impactadas.

- O ransomware foi distribuído via atualização maliciosa.
- O ataque utilizou PowerShell e certutil.exe.
- O malware desativou mecanismos do Windows Defender.
- Foram observadas técnicas de DLL Side-Loading.
- Houve criptografia massiva de arquivos locais e compartilhamentos de rede.
- A campanha demonstrou características de Supply Chain Attack.
- O objetivo principal aparenta ter sido extorsão financeira via ransomware.

1. Assessment

A campanha REvil contra a Kaseya representa um dos ataques mais sofisticados e impactantes já direcionados contra provedores de serviços gerenciados. O comprometimento de servidores VSA permitiu que os agentes da ameaça utilizassem a própria infraestrutura legítima da Kaseya como vetor de propagação do ransomware.

A utilização de softwares RMM como superfície de ataque aumenta significativamente o impacto operacional de campanhas de ransomware, visto que esses sistemas normalmente possuem privilégios administrativos elevados, acesso remoto e comunicação direta com múltiplos endpoints corporativos.

A análise da campanha sugere que os agentes do REvil priorizaram velocidade de execução e máxima disseminação da carga maliciosa. Diferentemente de outras operações do grupo, não foram observadas evidências claras de exfiltração massiva de dados ou comunicação contínua com infraestrutura de C2 durante a fase de criptografia.

Com alta confiança, avalia-se que:

- O REvil possuía conhecimento prévio da vulnerabilidade antes da liberação pública da correção.
- O ataque foi cuidadosamente planejado para maximizar o impacto antes da aplicação dos patches.



- MSPs continuarão sendo alvos prioritários de grupos ransomware devido ao potencial de acesso em larga escala.
- Ferramentas RMM continuarão sendo exploradas como vetores de propagação e persistência.

2. Principais lacunas de inteligência

- Não há confirmação pública completa sobre como o REvil obteve a vulnerabilidade explorada.
- Não existe confirmação definitiva sobre possível acesso prévio à infraestrutura interna da Kaseya.
- Ainda existem lacunas sobre o processo de seleção das vítimas.
- Não há total clareza sobre possíveis mecanismos de persistência utilizados antes da detonação do ransomware.
- Não foi possível confirmar integralmente a existência de exfiltração de dados durante a campanha.
- Existem limitações quanto à identificação de todos os IOCs utilizados durante o ataque.



3. Tabela MITRE ATT&CK (baseada na versão v12)

Tabela 1. Tabela MITRE &CK

Attribution	Tactics	Techniques	Sub Technique	Procedure	D3FEND	Deployed Control
REvil	Initial Access	T1190- Exploit Public-Facing Application	-	Exploração da CVE-2021-30116 em servidores Kaseya VSA expostos para contornar autenticação.	D3-SP - Software Patching Ref.: Link	Isolamento imediato dos servidores VSA da internet pública e aplicação mandatória do patch de correção emergencial VSA 9.5.7a.
REvil	Initial Access	T1195- Supply Chain Compromise	.002	Distribuição de ransomware via sequestro da cadeia de suprimentos, utilizando as ferramentas de gerenciamento e canais de atualização legítimos de um MSP para infectar a rede dos clientes.	D3-SVA - Software Supply Chain Verification Ref.: Link	Implementação de regras de privilégio mínimo em ferramentas RMM e segmentação rígida entre redes de MSPs e redes financeiras internas.
REvil	Execution	T1059 PowerShell	- .001	Execução de strings em PowerShell para desativar funcionalidades de monitoramento do Windows	D3-SCA - Script Execution Analysis	Habilitação do Script Block Logging (Event ID 4104) no Windows

Attribution	Tactics	Techniques	Sub Technique	Procedure	D3FEND	Deployed Control
				Defender em tempo real e de comportamento.	Ref.: Link	Event Log e bloqueio do PowerShell em modo restrito por GPO para usuários comuns.
REvil	Defense Evasion	T1562 - Impair Defenses: Disable or Modify Tools	.001	Uso de comandos de sistema via PowerShell para desativar proteções nativas (Set-MpPreference -DisableRealtimeMonitoring \$true).	D3-DA - Antivirus Evasion Detection Ref.: Link	Configuração de alertas críticos do SIEM baseados na execução de argumentos como "-DisableRealtimeMonitoring" e modificações de chaves do Windows Defender.
REvil	Defense Evasion	T1574 - DLL Side-Loading	.002	O binário legítimo do Windows Defender (MsMpEng.exe) foi copiado e forçado a carregar uma DLL maliciosa modificada (MpSvc.dll) presente no mesmo diretório.	D3-FA - File Analysis / Execution Prevention	Monitoramento de integridade de arquivos (FIM) e regras de EDR para detectar instâncias do MsMpEng.exe executando fora do diretório padrão do sistema (System32 / Program Files).

Attribution	Tactics	Techniques	Sub Technique	Procedure	D3FEND	Deployed Control
REvil	Discovery	T1046 - Network Service Scanning		Varredura ativa e automatizada de redes internas comprometidas com foco específico na identificação de sistemas de Ponto de Venda (PoS) para exfiltração de dados de cartões.	D3-NSD (Network Service Discovery Detection)	Monitoramento de tráfego interno anômalo originado de endpoints comuns em direção a portas e redes que hospedam servidores e terminais de pagamento/PoS.
REvil	Impact	T1490 - Inhibit System Recovery		Execução automática de comandos vssadmin.exe via WMI para deletar Shadow Copies de forma silenciosa (/quiet) impedindo a recuperação de arquivos.	D3-BDA - Boot Data Protection Verification	Bloqueio via regras de redução de superfície de ataque (ASR) da execução do vssadmin.exe por processos não autorizados. Segregação de backups offline imutáveis.

Fonte: Elaborado pelos Autores (2026)

Análise Comportamental Adicional (Argumento de Ofuscação): O artefato binário empregado pelo REvil possui uma camada de proteção analítica contra ambientes automatizados (sandboxes). O malware avalia a presença do argumento de linha de comando -t acompanhado por um valor específico de 4 bytes antes de prosseguir com a rotina de descryptografia de suas strings internas e execução das rotinas de ataque. A ausência desse argumento causa o encerramento seguro do processo sem atividade maliciosa aparente.

4. Cronograma de atividades

Tabela 2. Cronograma de atividades

Attribution	Start Date	End Date	Location	Sector	Activity
REvil	02/07/2021	02/07/2021	Global	MSPs / Diversos	Início da exploração do <i>0-day</i> , distribuição via <i>supply-chain</i> e criptografia de 1.500+ redes.
Kaseya	02/07/2021	02/07/2021	Global	Tecnologia	Kaseya desliga servidores SaaS e alerta para clientes <i>on-premises</i> desligarem servidores.
Kaseya	03/07/2021	03/07/2021	Global	Tecnologia	Lançamento da ferramenta <i>Compromise Detection Tool</i> pela Kaseya.
REvil	05/07/2021	05/07/2021	-	-	Grupo REvil exige resgate universal de US\$ 70 milhões em portal na dark web.
Kaseya	11/07/2021	11/07/2021	Global	Tecnologia	Kaseya disponibiliza o <i>patch</i> oficial (9.5.7a) para servidores VSA <i>On-Premises</i> .
REvil	13/07/2021	13/07/2021	-	-	A infraestrutura e os sites na dark web do grupo REvil desaparecem repentinamente.
Terceiros	22/07/2021	22/07/2021	Global	-	Kaseya obtém uma chave/ferramenta de descryptografia universal (Decryptor) para todas as vítimas.

Fonte: Elaborado pelos Autores (2026)

5. Indicators of Compromise (IOC)

5.1. Malware

Tabela 3. Malware

Attribution	Malicious Tool Name	Hash Type	File Hash	Associated Files Hash	Brief Description	Malware Analysis Report (Hyperlink, or N/A)	First Reported	Last Reported
REvil	agent.crt	MD5	939aae3cc456de8964cb182c75a5f8cc	Não identificado	Conteúdo malicioso codificado entregue no ataque.	N/A	02/07/2021	23/07/2023
REvil	agent.exe	MD5	561cffbaba71a6e8cc1cdceda990ead4	Não identificado	Executável gerado com conteúdo decodificado do agent.crt.	VirusTotal	02/07/2021	23/07/2023
REvil	mpsvc.dll	MD5	a47cf00aedef769d60d58bfe00c0b5421	Não identificado	A DLL que atua como o <i>payload</i> final do Ransomware.	N/A	02/07/2021	27/07/2023

Fonte: Elaborado pelos Autores (2026)

5.2. Rede

Tabela 4. Rede

Attribution	Network Artifact	Details	Intrusion Phase	First Reported	Last Reported
REvil	35.226.94[.]113	IP reportado acessando servidores com Kaseya VSA.	Intrusion	02/07/2021	06/07/2021
REvil	161.35.239[.]148	IP reportado acessando servidores com Kaseya VSA.	Intrusion	02/07/2021	06/07/2021
REvil	162.253.124[.]162	IP reportado acessando servidores com Kaseya VSA.	Intrusion	02/07/2021	06/07/2021

Fonte: Elaborado pelos Autores (2026)

5.3.Artefatos do sistema

Tabela 5. Artefatos do sistema

Attribution	Host Artifact	Type	Details	Tactic	First Reported	Last Reported
REvil	cert.exe	Executável	Utilitário legítimo do Windows renomeado (certutil) com uma string randômica para decodificar artefatos sem detecção.	Defense Evasion	02/07/2021	06/07/2021
REvil	MsMpEng.exe	Executável	Binário antigo da Microsoft abusado para executar <i>DLL Side-Loading</i> da biblioteca mpsvc.dll.	Defense Evasion	02/07/2021	N/A

Fonte: Elaborado pelos Autores (2026)

5.4.Common Vulnerabilities and Exposures (CVEs)

Tabela 6. Common Vulnerabilities and Exposures (CVEs)

Attributi on	CVE Number	CV SS Sco re	Patch Available (Y/N)	Other Remediation	Date Reported	Patch Applied (Y/N/UNK/NA)
REvil	CVE-2021-30116	9.8	Y	Ferramenta de detecção Kaseya / Desligamento temporário do servidor / Hardening do IIS.	02/07/2021	Y (A partir de 11/07/2021)

Fonte: Elaborado pelos Autores (2026)

6. Assinaturas:

Nome da Infecção: Ransomware REvil (Kaseya Supply Chain)

Deteção: Assinaturas YARA focadas em artefatos como agent.exe e mpsvc.dll.

Tabela 7. Regra Yara

```
rule REvil_Kaseya_MpSvc_DLL {
  meta:
    description = "Detecta mpsvc.dll maliciosa usada no ataque Kaseya 2021"
    author      = "CTI-KSA07"
    hash_md5    = "a47cf00aedf769d60d58bfe00c0b5421"
  strings:
    $mz = { 4D 5A }
```



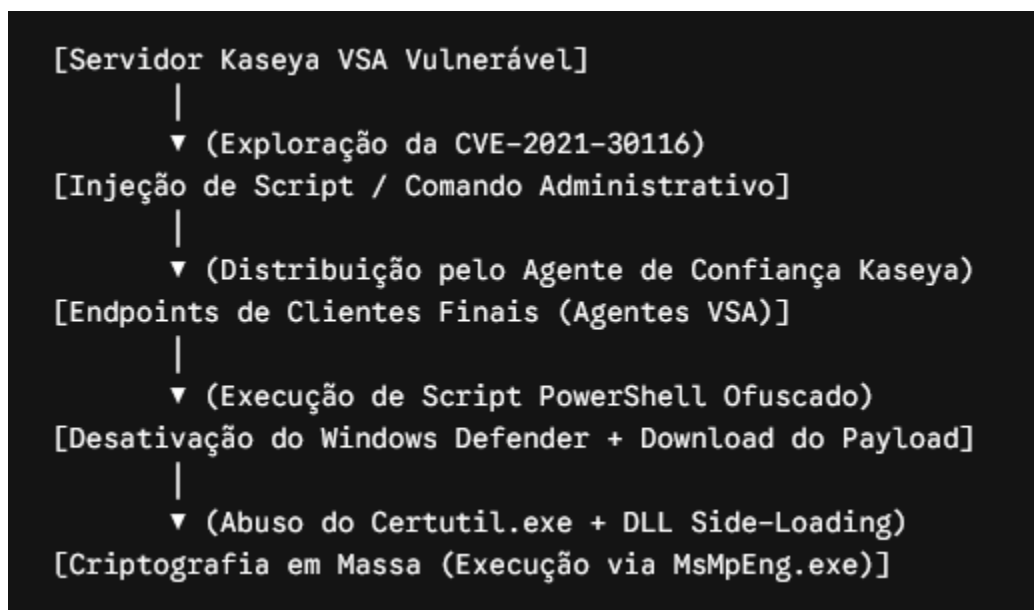
```
$s1 = "MsMpEng.exe" ascii nocase  
$s2 = { 52 45 76 69 6C } // "REvil"  
condition:  
  $mz at 0 and all of ($s1, $s2)  
}
```

Fonte: Elaborado pelos Autores (2026)



7. O Fluxo da Infecção (Kill Chain)

Figura 1. Fluxo da Infecção



Fonte: Autores (2026)

Acesso e Injeção: Uma vez dentro do console administrativo VSA, o atacante gerou uma tarefa automatizada falsa de atualização de segurança denominada Kaseya VSA Agent Hotfix.

Propagação Automatizada: Como os agentes VSA instalados nas máquinas das vítimas possuem privilégios administrativos máximos no sistema operacional (SYSTEM), eles aceitaram a ordem do servidor central e baixaram os pacotes maliciosos sem qualquer contestação.

Execução em Lote: O comando enviado disparou uma string em PowerShell altamente ofuscada que executou três ações consecutivas:

Desativou os componentes de monitoramento em tempo real do antivírus local (*Windows Defender*).

Utilizou o utilitário legítimo do Windows certutil.exe para decodificar um arquivo binário oculto (agent.crt).

Extraíu dois arquivos no diretório de destino: um executável legítimo e antigo da Microsoft (MsMpEng.exe) e uma biblioteca dinâmica corrompida (mpsvc.dll).

Padrões de Linha de Comando (PowerShell)

```
cmd.exe /c ping 127.0.0.1 -n 4913 > nul &
C:\Windows\System32\WindowsPowerShell\v1.0\powershell.exe Set-MpPreference -
DisableRealtimeMonitoring $true -DisableIOAVProtection $true -DisablePrivacyMode $true -
DisableBehaviorMonitoring $true -DisableBlockAtFirstSee $true -ThreatIDDefaultAction_Ids
@(2147710330, 2147714189, 2147714202, 2147714203) -ThreatIDDefaultAction_Actions
@(6, 6, 6, 6) -Force
```

8. Avaliação de Risco, Relevância Setorial e Lacunas de Inteligência

8.1. Análise de Risco de Cadeia de Suprimentos (Supply Chain)

Para o setor de Serviços Financeiros, o incidente envolvendo a plataforma Kaseya VSA valida uma tese crítica de governança: a postura de segurança de fornecedores terceiros correlaciona-se diretamente com o risco residual da própria instituição. Softwares de Monitoramento e Gerenciamento Remoto (RMM) operam com privilégios administrativos elevados ('SYSTEM') e, por design, possuem canais de comunicação diretos e "confiáveis" com o núcleo das redes corporativas. Isso os transforma em vetores ideais para ataques de distribuição em massa de cargas maliciosas, contornando perímetros tradicionais de defesa através de pacotes de atualização falsificados.

8.2. Atribuição e Geopolítica do Adversário

Avaliamos com Alta Confiança que esta campanha é de responsabilidade do grupo cibercriminoso GOLD SOUTHFIELD (operadores do ransomware REvil / Sodinokibi). Observou-se um comportamento anômalo em meados de 2021: logo após a execução de ataques de alto perfil global (como JBS e Kaseya) e o subsequente engajamento diplomático direto entre os governos dos Estados Unidos e da Rússia, o grupo encerrou suas operações públicas e desativou sua infraestrutura de extorsão de forma abrupta.

8.3.Lacunas de Inteligência (Intelligence Gaps)

Permanece como a principal lacuna de inteligência o paradeiro e o status operacional dos desenvolvedores e operadores seniores do núcleo do REvil. Diante da pressão geopolítica exercida na época, é Altamente Provável (80-95%) que o grupo tenha realizado um rebranding estratégico ou que seus membros tenham sido absorvidos por outras operações ativas de Ransomware-as-a-Service (RaaS). Esta fragmentação permite que os atacantes mantenham os mesmos TTPs e códigos-fonte sob novas nomenclaturas e identidades visuais.

9. Contramedidas, Recomendações de Defesa e Lições Aprendidas (Mapeamento MITRE D3FEND™)

Para mitigar ameaças que explorem canais de gerenciamento e táticas de Supply Chain, as seguintes diretrizes técnicas e posturas de engenharia de defesa são mandatórias:

9.1.Controles de Tráfego de Rede (Network Traffic Filtering)

- Isolamento de Redes Administrativas e DMZ: Servidores de gerenciamento de patches, ferramentas RMM e consoles centrais devem operar dentro de zonas de rede estritamente segmentadas (DMZs restritas). É vedada a exposição direta à internet pública ou o compartilhamento de credenciais administrativas entre domínios de produção corporativos e consoles RMM.
- Implementação de Proteção em Camada de Aplicação (WAF/CDN): Implementar inspeção profunda de tráfego HTTP/HTTPS para identificar e bloquear assinaturas de exploração de vulnerabilidades web (como desvios de autenticação) direcionadas contra as interfaces de gerenciamento.
- Filtragem Estrita de Tráfego de Entrada (Inbound Filtering): Restringir o acesso a consoles de administração exclusivamente por meio de túneis VPN corporativos e estabelecer listas de IPs autorizados (whitelisting), limitando conexões apenas aos endereços oficiais de serviços de CDN/SaaS utilizados (ex: Cloudflare).

9.2. Controles de Endpoint e Arquitetura de Detecção Avançada (Platform Hardening & File Analysis)

- **Análise Comportamental via EDR/XDR:** As defesas de endpoint não devem depender exclusivamente de assinaturas de arquivos ou hashes conhecidos. Os sistemas de monitoramento devem ser configurados para gerar alertas de severidade crítica e bloqueios automáticos caso processos legítimos do sistema operacional (como ‘MsMpEng.exe’ ou ‘certutil.exe’) realizem conexões de rede atípicas, chamadas de sistema anômalas ou modificações de arquivos em lote.
- **Hardening e Auditoria de PowerShell:** Impor a implementação rigorosa do PowerShell Constrained Language Mode por meio de Políticas de Grupo (GPO). Garantir a centralização de logs em um ambiente SIEM, monitorando ativamente os eventos de auditoria do PowerShell (Event IDs 4103 e 4104) para a detecção precoce de comandos ofuscados, injeções em memória ou tentativas de desativação de ferramentas protetivas.
- **Monitoramento de Processos e Abuso de WMI:** Estabelecer regras de detecção para interceptar comandos originados por scripts ou automações RMM com privilégios ‘SYSTEM’. Toda chamada de comando que envolva o uso do Windows Management Instrumentation (WMI) para encerrar processos de software de segurança corporativa deve acionar um protocolo de resposta a incidentes.
- **Detecção de Comprometimento por DLL:** Executar varreduras periódicas orientadas pelos manuais oficiais de hardening dos fornecedores de software para identificar artefatos órfãos, trajetórias de arquivos anômalas ou sequestros de execução relacionados à manipulação da biblioteca ‘CLDAP.dll’.

9.3. Recuperação, Resiliência e Continuidade de Negócios

- **Validação de Mecanismos de Decriptação:** Confirma-se a disponibilidade histórica de um decriptador universal legítimo para as vítimas afetadas por esta variante específica do REvil (disponibilizado em 21 de julho de 2021). O utilitário foi validado por laboratórios de

segurança especializados (como a Emsisoft), demonstrando eficácia na restauração de dados criptografados sem a necessidade de concessão às extorsões financeiras.

- Políticas de Backup Imutável: Como lição estratégica de resiliência, as organizações do setor financeiro devem assegurar que seus planos de continuidade contem com rotinas de backup offline, isolados da rede principal (air-gapped) ou sob arquitetura imutável, impossibilitando que agentes de ransomware utilizem comandos de destruição (como ‘vssadmin’) para invalidar os pontos de recuperação.

10. Matriz de probabilidade

Quase sem chance	Muito improvável	Improvável	Chance praticamente igual	Provável	Muito provável	Quase com certeza)
01–05%	05–20%	20–45%	45–55%	55–80% Panejamento prévio	80–95%	95–99% Atribuição ao REvil

11. Feedback

Se este relatório atendeu aos Requisitos de Inteligência e às necessidades operacionais, ou caso necessite de novas detecções baseadas nos TTPs apresentados, entre em contato via e-mail com: pgco0012@acaditi.com.br (Threat Hunt).

Threat Actor:	• REvil / Sodinokibi (Associados a PINCHY SPIDER / GOLD SOUTHFIELD)
Victim Location:	• Global (EUA, Reino Unido, Brasil/América Latina, África do Sul, Canadá, Alemanha, Colômbia, entre outros).
Sectors:	• Provedores de Serviços Gerenciados (MSPs), Governo, Serviços Profissionais, Varejo, Setor Financeiro, Saúde e Atacado.
Infrastructure Used	• Exploração de servidores expostos (Kaseya VSA On-Premises), GitHub, Pastebin, Amazon CloudFront (C2).

Actor Motivation:

- Cyber Crime / Ransomware (Operação Financeira de Extorsão RaaS).